

1 de junio
2026

Clase 9

Seguridad en Aplicaciones

CWE Top 25:
Debilidades de SW más peligrosas
(Common Weakness Enumeration)

- Fáciles de encontrar y explotar.
- Pueden permitir a un adversario el control del Sistema, robar datos o impedir el funcionamiento de aplicaciones.
- Puntaje en función de **frecuencia** y de **impacto/daño** (principalmente)
- Analizan: Etapa del ciclo de vida / Lenguajes / Consecuencias

<http://cwe.mitre.org/top25>

2011:

- Interacción insegura entre componentes
- Manejo riesgoso de recursos
- Defensas abiertas/porosas

https://cwe.mitre.org/top25/archive/2011/2011_cwe_sans_top25.html

2025: Research concepts - Pillars

- Improper Neutralization
- Improper Control of a Resource Through its Lifetime
- Protection Mechanism Failure.
- Improper Access Control
- Improper Adherence to Coding Standards.
- Incorrect Calculation.
- Improper Interaction Between Multiple Correctly Behaving Entities.
- Insufficient Control Flow Management.
- Incorrect Comparison.
- Improper Check or handling of exceptional conditions.

<https://cwe.mitre.org/data/definitions/1000.html>

2025:

https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html

Neutralización inadecuada

Asegurarse que input/output tiene ciertas propiedades antes de usarse.

- | | |
|---|---|
| 1. 'Cross-site Scripting' (XSS) (rank: 1) | 4. 'Code injection' (rank: 10) |
| 2. SQL Injection (rank: 2) | 5. Improper input validation (rank: 18) |
| 3. OS command injection (rank: 9) | 6. 'Command injection' (rank: 23) |

Control inapropiado de un recurso

Creación, uso y destrucción de recurso se debe hacer correctamente.

1. Out of bounds Write (rank: 5)
2. Path Traversal (rank: 6)
3. Use after free (rank: 7)
4. Out of bounds Read (rank: 8)
5. Buffer Copy without Checking size of input (Classic Buffer Overflow) (rank: 11)
6. Unrestricted Upload of File with Dangerous Type (rank: 12)
7. Stack-based Buffer Overflow. (rank: 14)
8. Deserialization of Untrusted Data (rank: 15)
9. Heap-based Buffer Overflow (rank: 16)
10. Exposure of Sensitive Information to an Unauthorized Actor (rank: 20)
11. Server-Side Request Forgery (SSRF) (rank: 22)
12. Allocation of Resources Without Limits or Throttling (rank: 25)

Control de acceso inapropiado

Autenticación, autorización y registro.

1. Missing Authorization (rank: 4)
2. Control de acceso inapropiado (rank: 19)
3. Incorrect Authorization (rank: 17)
4. Missing Authentication for Critical Function (rank: 21)
5. Authorization Bypass through user-controlled key (rank: 24)

Falla en Mecanismos de protección

Mal uso / No uso de mecanismos de protección.

1. Cross-Site Request Forgery (CSRF) (rank: 3)

Otros

Cálculos incorrectos

- Integer Overflow or Wraparound (rank: 30)

Chequeo inapropiado de condiciones excepcionales (estándares de Código).

- NULL Pointer Dereference (rank: 13)

Manejo insuficiente del flujo de control.

- Race condition (rank: 36)

https://cwe.mitre.org/top25/archive/2025/2025_onthecusp_list.html